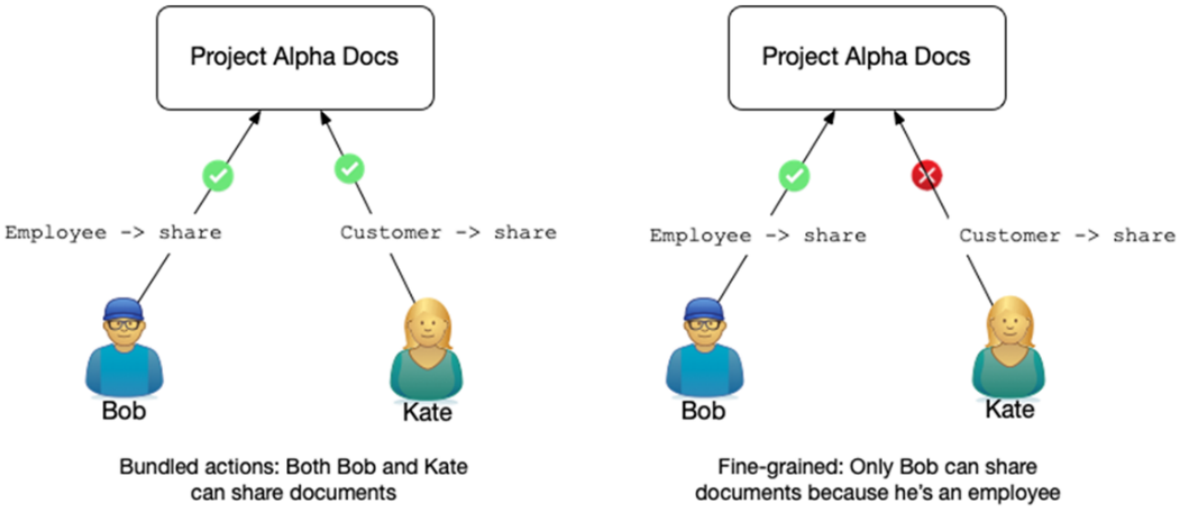


Figure 10.4 Bundled versus fine-grained actions. In the bundled approach, both employees and customers can share documents, while in the fine-grained approach, only employees are able to share, giving ACME precise control while keeping ease of use.

Separating capabilities this way restored clarity. Customers could still collaborate on project work by viewing and editing documents, while only employees retained the ability to share them externally. Where the bundled `doc:all` action had blurred distinctions and led to over-permissioning, fine-grained rules clarified the boundaries. ACME could present simple roles in the UI without sacrificing precision or security in the underlying policies.

10.1.5 Stability across change

Organizations evolve: teams reorganize, employees change roles, and projects are launched or terminated. Policies must adapt to these changes. At ACME, a brittle policy once linked document access strictly to an employee's job title. Dan, who started as an Associate Counsel, was later promoted to Senior Counsel. His responsibilities stayed the same, but because the policy only checked for an exact title, he suddenly lost access to legal drafts he needed to do his job.

BRITTLE POLICY (TIED TO JOB TITLE)

Here's how ACME initially approached it: